Abanoub Rodolf Boctor
Founder & CTO, ThynkQ

I found an exposed API token hiding in my AI config.

Here's what I built to fix it.

10	14	43+
SECURITY SCANNERS	AI TOOLS SUPPORTED	SECRET PATTERNS

Swipe to see what it catches →

⚠ THE PROBLEM

MCP servers have privileged access.

Nobody is auditing them.

🔑 **File system access**
Read and write your entire disk

🌐 **Network calls**
Exfiltrate data without you knowing

🗡️ **Prompt injection**
Hijack your entire AI session

🔒 **No audit trail**
Zero visibility into what actually ran

🔍 THE SOLUTION

Introducing mcp-scan

One command. No install needed.

⚡ **10 security scanners**
Secrets, injection, typosquatting, AST analysis, and more

🖥️ **14 AI tools supported**
Claude Desktop, Cursor, VS Code, Windsurf, Zed, Copilot...

📦 **Open source, MIT license**
Audit the scanner itself. Zero trust required.

WHAT IT CATCHES

Exposed secrets sitting in plaintext configs

I ran it on my own setup. Found this:

```
# ~/.claude/claude_desktop_config.json
"GITHUB_TOKEN": "ghp_a8Kx...redacted"
# Exposed since October. Full repo access.
# Anyone with disk access could grab it.
```

mcp-scan checks for 43+ secret formats:

- GitHub tokens, OpenAI keys, Stripe keys, AWS credentials
- Anthropic API keys, Slack tokens, database URLs
- Any high-entropy string that looks like a secret

🚨 PROMPT INJECTION

Tool descriptions can contain hidden instructions.

Your AI follows them blindly.

🗡️ **IGNORE ALL PREVIOUS INSTRUCTIONS**
This pattern hides in tool metadata, not in prompts you see

🌐 **Exfil URLs in descriptions**
Tool says 'send results to evil.com' and the model complies

🎭 **Tool name shadowing**
A malicious server registers the same tool name as a trusted one

🚨 SUPPLY CHAIN

Nobody verifies the npm packages in your MCP config.

Typosquatting is trivial.

📦 **Typosquatted packages**
modeicontextprotocol vs modelcontextprotocol (spot the difference?)

🔍 **Known malicious packages**
Checked against a maintained blocklist, updated with community reports

⚠️ **Overly broad permissions**
Filesystem paths defaulting to / instead of scoped to your project

🔬 AST ANALYSIS

Static analysis catches what pattern matching misses.

Parses actual source code.

🐚 **Reverse shell detection**
child_process.exec piped to curl or nc patterns

⚡ **eval() on untrusted input**
Server scripts that evaluate arbitrary strings

📡 **Data exfiltration patterns**
cat ~/.ssh | nc, fetch() to unknown hosts

✅ THE FIX

Run this right now.

Takes 30 seconds.

```
npx mcp-scan
# no install required, just run it
```

1. **Run the command above**
   Works on Mac, Linux, Windows

2. **Review flagged servers**
   mcp-scan explains every finding clearly

3. **Remove or audit risky ones**
   Disable until you can verify the source

4. **Add to your CI/CD**
   Catch issues before they reach production

⭐ OPEN SOURCE

Free. Open source. Help make MCP safer.

⭐ **Star the repo**
Show the community this matters

🐛 **Report issues**
False positive or missed vuln? Open an issue

🔍 **Submit signatures**
Add detection patterns you discover

📢 **Share this post**
Every developer using AI tools should know

Abanoub Rodolf Boctor
Founder & CTO, ThynkQ

Secure your MCP stack.

One command. Free. Now.

```
npx mcp-scan
```

npm: npmjs.com/package/mcp-scan

GitHub: github.com/rodolfboctor/mcp-scan

Follow for more security deep-dives

If this helped you, share it. Someone on your team needs to see this.